MODULE 05 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

CloudTrail and the Audit Trail

Who did what, when, from where - and proving afterwards that nobody edited the answer.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 5 of 35

admin@sthithapragna.com

CloudTrail records **actions**, not state and not performance. Every question in this area starts by deciding which of those three you need.

Three questions, three services

THE QUESTION BEING ASKED	THE SERVICE THAT ANSWERS IT
Who deleted the bucket, and when?	CloudTrail. It records API calls and their callers
What did that security group look like on Tuesday?	AWS Config. It records configuration state over time
Are any buckets public right now?	AWS Config. Current state, queried
Is this instance running out of memory?	CloudWatch. Metrics and logs
Tell me when errors exceed a threshold	A CloudWatch alarm

ON THE EXAM

Who did it, what it looked like, how it is performing. Three questions, and the wording of a scenario always picks one.

Event history: what you get for nothing

- **90 days** of history, free, viewable and searchable in the console. On by default and it cannot be turned off.
- **Management events only.** No data events, and no Insights events.
- **Per account, per Region.** There is no single view across the organisation.
- Beyond 90 days, or for anything else on that list, you need a **trail**.

> ON THE EXAM
>
> "We do not need a trail because CloudTrail is already on" is the reasoning a scenario will hand you. It is wrong the moment the requirement exceeds 90 days.

Four event types

EVENT TYPE	WHAT IT CAPTURES, AND WHAT IT COSTS
Management	Control plane: create, delete, configure. ON by default. First copy free per Region
Data	Data plane: S3 object access, Lambda invoke, DynamoDB items. OFF by default. Charged from the first copy
Insights	Unusual API call rate or error rate. OFF by default. Charged per event analysed
Network activity	API calls traversing your VPC endpoints. OFF by default. Charged

ON THE EXAM

Only management events are on by default. Three of the four types are opt-in, and that is where both the marks and the bill live.

Data events, and how to afford them

- **Never on by default**, and there is no free first copy. Logging every object in a busy bucket is genuinely expensive.
- **Advanced event selectors** narrow by resource ARN, event name, read or write, and more.
- Log **write events on the sensitive bucket** rather than all events on all buckets. Same evidence, a fraction of the volume.
- Without data events, **a deleted object never appears in CloudTrail at all**. The management event only shows the bucket being configured.

> ON THE EXAM
>
> "Who deleted that object?" is unanswerable unless S3 data events were already enabled. Being able to say so is worth a mark.

Three ways the CloudTrail bill explodes

- **The second copy.** A multi-Region trail plus a single-Region trail means events are logged twice, and copy two is charged.
- **Data events left wide open.** All buckets, all objects, read and write. This is the big one.
- **SSE-KMS on a busy bucket.** Every object operation generates KMS management events, which are then logged.
- A well designed management-events-only multi-Region trail costs close to nothing in CloudTrail fees.

> ON THE EXAM
>
> Storage in S3 is a separate charge from CloudTrail itself. A scenario blaming CloudTrail for a bill may actually be describing S3.

Network activity events: the newer one

- Records **AWS API calls traversing your VPC endpoints**, generally available since February 2025.
- Filter on **vpcEndpointId**, **eventName**, and **errorCode** - where the only valid error code is **VpceAccessDenied**.
- Log **access denied only** and you get data-perimeter evidence at a tiny fraction of the volume.
- Since July 2026 you can also filter by **the calling IAM identity**, so trusted roles can be excluded.

> ON THE EXAM
>
> This answers "did anyone use credentials from outside our organisation at our endpoint?" without decrypting any traffic.

CloudTrail Insights

- Detects **unusual API call rate** and **unusual API error rate** against a learned baseline.
- **Prerequisites bite:** call rate needs Write management events logged; error rate needs Read or Write.
- Catches a runaway script, a misconfigured deployment loop, or credentials being probed.
- Charged per event analysed, per insight type. It is opt-in on the trail.

> ON THE EXAM
>
> Insights is anomaly detection for API activity, the same idea as CloudWatch anomaly detection but applied to who is calling what.

Organization trails

- Created **once** in the management account or a delegated administrator, and it covers **every account**, including ones created later.
- **Member accounts cannot alter or delete it.** They can see it exists and nothing more.
- The **management account always owns it**, whoever created it, so removing a delegated admin leaves the trail intact.
- Make it **multi-Region**. Global service events such as IAM and STS are recorded in us-east-1.

> ON THE EXAM
>
> A per-account trail is only as trustworthy as that account's administrator. That is the entire argument for an organization trail.

Proving nobody edited the evidence

- **Log file integrity validation** writes an hourly **digest file** containing hashes of every log file delivered in that hour.
- Log files are hashed with **SHA-256**; digests are signed with the private key of a CloudTrail key pair.
- Verify with **aws cloudtrail validate-logs**. It proves files are unmodified, and that none were deleted.
- **It is off by default.** An auditor asking for tamper evidence is asking for this switch.

> ON THE EXAM
>
> Digests chain to the previous hour, so deleting a whole log file is detectable too, not just editing one.

Protecting the bucket the trail writes to

- Put it in a **separate, tightly controlled account**, so an attacker in the workload account cannot reach it.
- **S3 Object Lock** in compliance mode makes objects undeletable for a retention period, even by the root user.
- **MFA delete** on the bucket, **versioning** on, and a bucket policy that denies deletes.
- Encrypt with **SSE-KMS** and control who can decrypt separately from who can read the bucket.

> ON THE EXAM
>
> Integrity validation detects tampering. Object Lock prevents it. Auditors usually want both, and questions often want the preventive one.

How an event travels

01

API call

Console, CLI, SDK or a service acting on your behalf.

›

02

CloudTrail

Records it as an event, if the type is enabled.

›

03

EventBridge

Management events reach the default bus in near real time.

›

04

S3

Log files delivered, typically within 15 minutes.

›

05

CloudWatch Logs

Optional. Enables metric filters and alarms.

ON THE EXAM

Two speeds. EventBridge is near real time; S3 delivery lags. Choose by how fast the scenario needs to react.

React fast, or investigate later?

EVENTBRIDGE WHEN

Seconds matter

- Rule on the default bus matching the API call
- Target a Lambda function or SSM Automation
- Near real time, no S3 delivery wait
- Management events only, without a data trail

S3 PLUS ATHENA WHEN

Depth matters

- Query months of history across accounts
- Joins, aggregation, arbitrary questions
- Minutes to hours behind live
- The forensic and compliance path

THE TIEBREAKER

Automatically revert an unauthorised change is EventBridge. Work out who has been doing this for six months is Athena over the bucket.

Reading an event record

- **userIdentity** is where investigations start. Type, ARN, and for assumed roles the **sessionContext**.
- An assumed-role event names the **role**. The human is in **sessionIssuer** and the session name, so name sessions after people.
- **eventSource** and **eventName** identify the call; **sourceIPAddress** and **userAgent** say where from.
- **errorCode** and **errorMessage** appear on failures. A denied call is still recorded, which is often the interesting one.

> ON THE EXAM
>
> Failed calls are logged too. "Nothing shows in CloudTrail" usually means the event type was off, not that nothing happened.

Honest limit: CloudTrail Lake is closed to new customers

- **Closed to new customers on 31 May 2026.** Existing customers continue as normal.
- It now receives **critical bug fixes and security updates only**. Do not design anything new around it.
- **CloudTrail itself is fully supported.** Only Lake changed. Trails, event history and all four event types are unaffected.
- AWS points customers toward **CloudWatch** for comparable capability. Athena over the trail bucket remains the classic route.

> ON THE EXAM
>
> Exam material may still present Lake as a normal option. Learn what it does, and know you would not choose it for a new build today.

> A finance team reports that a spreadsheet stored in S3 disappeared some time in the last week. The account has a multi-Region organization trail delivering management events to a central S3 bucket, with 400 days of retention.
>
> A CloudOps engineer searches CloudTrail Event history and the delivered log files, and finds no record of the object being deleted.

What is the most likely explanation?

A The event is older than the 90-day Event history window

B S3 data events were never enabled, so object-level operations were never recorded

C The organization trail does not cover the account that owns the bucket

D Log file integrity validation is disabled, so delete events were dropped

◆ PAUSE AND DECIDE

What is the most likely explanation?

A. Older than 90 days

The deletion happened in the last week, and the trail retains 400 days regardless. Both facts are stated to rule this out.

B. Data events were never enabled

Deleting an object is a data-plane operation. The trail logs management events only, so the deletion was never recorded anywhere.

C. Trail does not cover the account

An organization trail covers every account including new ones, and member accounts cannot exclude themselves.

D. Integrity validation disabled

Invented mechanism. Validation detects tampering after delivery; it never decides which events are captured.

THE SIGNAL

The scenario says "management events" once, quietly. That single word is the whole answer.

An external auditor wants proof that two years of CloudTrail logs have not been modified or deleted by anyone. That includes administrators with full access to the logging account.

The company has an organization trail delivering to a versioned S3 bucket in a dedicated logging account. A bucket policy denies s3:DeleteObject to everyone except the security team's role.

Which combination should the company implement?

A. Enable log file integrity validation, and apply S3 Object Lock in compliance mode to the bucket

B. Enable CloudTrail Insights and turn on MFA delete

C. Copy the log files nightly to a second bucket in another Region with a Lambda function

D. Enable S3 server access logging on the CloudTrail bucket

◆ PAUSE AND DECIDE

Which combination should the company implement?

A Integrity validation plus Object Lock

Validation proves nothing changed; compliance-mode Object Lock means nobody could have changed it, including root. Detective plus preventive.

B Insights plus MFA delete

Insights detects unusual API rates and is unrelated. MFA delete helps, but a determined administrator with the MFA device is not stopped.

C Nightly copy to another Region

Improves durability, not integrity. The same administrator can delete from both buckets, and a copy proves nothing about the original.

D S3 server access logging

Records who accessed the bucket. It is evidence about the evidence, and it is itself deletable by the same administrator.

THE SIGNAL

"Including administrators" rules out any control an administrator can undo. Compliance mode is the only option here that root cannot override.

> A security policy covers any change opening a security group to inbound traffic from 0.0.0.0/0 on port 22. Such a change must be automatically reverted within one minute, and the security team notified.
>
> The company has a multi-Region organization trail delivering to S3 and to a CloudWatch log group. An engineer proposes a nightly Athena query over the trail bucket to find such changes.

What should the company implement instead?

A Keep the Athena query but run it hourly instead of nightly

B An EventBridge rule on the default bus matching AuthorizeSecurityGroupIngress, targeting a Lambda function that reverts the rule and publishes to SNS

C A metric filter on the CloudWatch log group with an alarm that notifies the security team

D Enable CloudTrail Insights to detect the unusual API call

◆ PAUSE AND DECIDE

What should the company implement instead?

A Hourly Athena query

Still detection, still an hour late, and it does not revert anything. It answers neither half of the requirement.

B EventBridge rule to Lambda

Management events reach the default bus in near real time. Lambda both reverts the change and notifies, inside the one-minute window.

C Metric filter and alarm

The strongest wrong answer. It notifies, but it cannot revert, and trail delivery to the log group adds minutes before the filter even sees it.

D CloudTrail Insights

Detects unusual call volume, not a specific dangerous call. One deliberate change is not a rate anomaly.

THE SIGNAL

Two requirements: revert automatically, and within one minute. Option C fails the first; options A and C fail the second.

A company's CloudTrail costs rose from about $40 to over $3,000 a month. A project team had enabled data events for all S3 buckets, read and write, across a multi-Region trail. Auditors only require evidence of writes to one bucket holding regulated records.

The company also still has an old single-Region trail in eu-west-1 logging management events, created before the organization trail existed.

Which combination reduces the cost while meeting the audit requirement?

A. Switch the organization trail to the Infrequent Access log class

B. Use advanced event selectors to log write data events on the regulated bucket only, and delete the redundant single-Region trail

C. Disable data events entirely and rely on S3 server access logging for the regulated bucket

D. Reduce the S3 bucket lifecycle policy to move trail logs to Glacier after 30 days

◆ PAUSE AND DECIDE

Which combination reduces the cost while meeting the audit requirement?

A. Infrequent Access log class

Log classes are a CloudWatch Logs feature. A trail delivering to S3 has no log class, so this is a category error.

B. Scoped selectors, drop the second trail

Selectors cut the data-event volume to what auditors need, and removing the duplicate trail stops paying twice for management events.

C. Server access logging instead

Best-effort delivery, no guaranteed completeness, and no integrity validation. Weak evidence for a regulated record.

D. Glacier lifecycle

Reduces S3 storage, which is not where this bill came from. The charge is per event logged, not per byte stored.

THE SIGNAL

Both of this module's cost traps in one question: data events wide open, and a forgotten second copy of management events.

The five things to carry forward

- **Who did it, what it looked like, how it is performing.** CloudTrail, Config, CloudWatch.
- **Only management events are on by default.** No data events means a deleted object is simply unrecorded.
- **Integrity validation detects; Object Lock prevents.** "Including administrators" means you need the preventive one.
- **EventBridge in seconds, S3 in about 15 minutes.** The required reaction time picks the path.
- **CloudTrail Lake closed to new customers on 31 May 2026.** CloudTrail itself is unaffected.

> ON THE EXAM
>
> Next: EventBridge properly - buses, patterns, targets, and the many reasons a rule quietly does not fire.